

Détection des vulnérabilités

Stéphane Gill

Stephane.Gill@CollegeAhuntsic.qc.ca

Table des matières

Introduction.....	2
Outils de détection des vulnérabilités.....	2
Dsniff.....	3
Netcat.....	5
Nmap.....	5
Nessus.....	5
Whisker.....	6
VLAD.....	6
John the Ripper.....	6
Références.....	7

Document écrit par Stéphane Gill

© Copyright 2013 Stéphane Gill

Ce document est soumis à la licence GNU FDL.

Permission vous est donnée de distribuer, modifier des copies de ce document tant que cette note apparaît clairement.

Introduction

La détection des vulnérabilités d'un réseau consiste à faire une inspection de ce réseau et de son système de sécurité. Il existe deux approches à la détection des vulnérabilités :

- l'approche « boîte noire »;
- l'approche « boîte blanche ».

L'approche boîte noire consiste principalement à utiliser des outils informatiques qui, à partir d'une plage d'adresse, IP balayent, sondent et simulent des attaques sur le réseau afin d'en détecter les vulnérabilités potentielles.

L'approche boîte blanche consiste plutôt à demander à un expert externe de réviser l'architecture du réseau, les fichiers de paramétrage ainsi que les politiques de sécurité. Cette approche est supérieure à l'approche boîte noire mais elle est peu répandue.

Peu importe l'approche choisie la détection des vulnérabilités devrait se faire suivant une méthodologie. Malheureusement, il n'existe pas encore de méthodologie standard. Les organismes suivants proposent de l'information sur les méthodologies de détection de vulnérabilités :

- The Open Source Security Testing Methodology Manual (OSSTMM, www.isecom.org).
- The Open Web Application Security Project (www.owasp.org).

Outils de détection des vulnérabilités

Il existe de nombreux outils commerciaux de détection des vulnérabilités, en voici une courte liste :

- Axenl's NetRecon (www.axent.com)
- Cisco Secure Scanner (NetSonar) (www.cisco.com)
- Cybercop Scanner (www.pgp.com)
- ISS Internet Scanner (www.iss.net)
- Saint (www.saintcorporation.com)

- Nessus (www.tenable.com)

Il existe aussi une vaste gamme d'outils gratuits ou « Open Source » :

- Dsniff (www.monkey.org/~dugsong/dsniff/)
- Netcat (www.avian.org)
- Nmap (www.insecure.org)
- OpenVAS (www.openvas.org)
- John-the-ripper (www.openwall.com/john/)

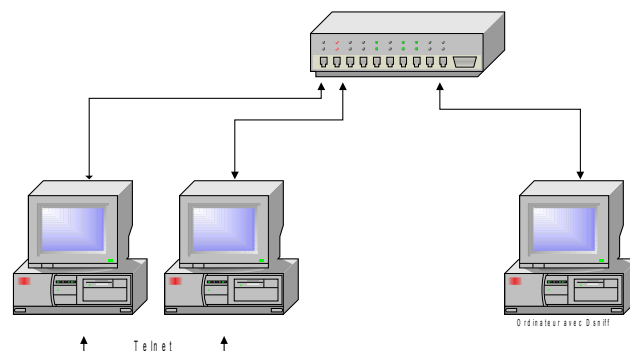
Les sections suivantes présentent quelques outils de détection des vulnérabilités.

Dsniff

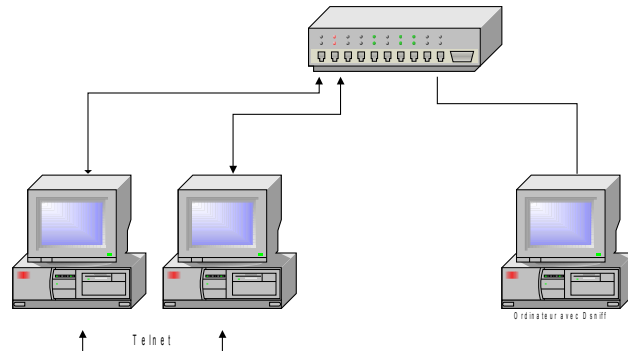
Dsniff est un renifleur de mot de passe qui supporte les protocoles FTP, telnet, SMTP, HTTP, POP, poppass, NNTP, IMAP, SNMP, LDAP, Rlogin, RIP, OSPF, PPTP MS-CHAP, NFS, YP/NIS, SOCKS, X11, CVS, IRC, AIM, ICQ, Napster, PostgreSQL, Meeting Maker, Citrix ICA, Symantec pcAnywhere, NAI Sniffer, Microsoft SMB, Oracle SQL*Net, Sybase et Microsoft SQL.

Dsniff inclus aussi un utilitaire pour intercepter les messages SMTP (mailsnarf) et les connexions http (urlsnarf, webspay).

Les renifleurs fonctionnent efficacement lorsque les ordinateurs sont reliés en réseau à l'aide d'un concentrateur. L'utilisation d'un concentrateur fait en sorte que les paquets d'une communication sont envoyés à tous les ordinateurs connectés sur ce concentrateur.



Lorsque les ordinateurs sont interconnectés à l'aide d'un commutateur, seuls les deux ordinateurs impliqués dans la communication reçoivent les paquets. Pour permettre l'utilisation d'un renifleur, il faut paramétrer une interface du commutateur de façon à ce qu'elle reçoive tous les paquets qui transitent sur ce commutateur.



Voici un exemple d'utilisation de Dsniff :

```
[root@pc-00068 root]# dsniff -c -m
Kernel filter, protocol ALL, raw packet socket
dsniff: listening on eth0 []
-----
10/09/03 09:23:05 tcp pc-00065.3729 -> 207.163.81.15.110 (pop)
USER s.gill
PASS UnKiki19
-----
10/09/03 09:23:08 tcp pc-00065.3730 -> poste.collegeahuntsic.qc.ca.110 (pop)
USER ca0792
PASS pipo69
```

Netcat

Netcat est un excellent utilitaire de tests multifonctions pour le réseau. Il permet entre autre de simuler des services, d'écouter l'activité sur un port donné. Il peut être à la fois client et serveur tcp. Netcat existe pour les plates-formes Windows et Linux.

Nmap

Nmap est un outil de balayage de port sophistiqué disponible aussi bien sous Linux, Unix et Windows. C'est habituellement le premier outil que l'on utilise pour détecter les vulnérabilités. Il permet d'identifier les services offerts par un ordinateur ainsi que d'identifier son système d'exploitation. Pour utiliser Nmap il suffit de taper `nmap` suivi de l'adresse IP ou du nom de l'hôte de la machine à balayer comme dans l'exemple suivant :

```
[root@Linux1 root]# nmap fw1.collegeahuntsic.qc.ca

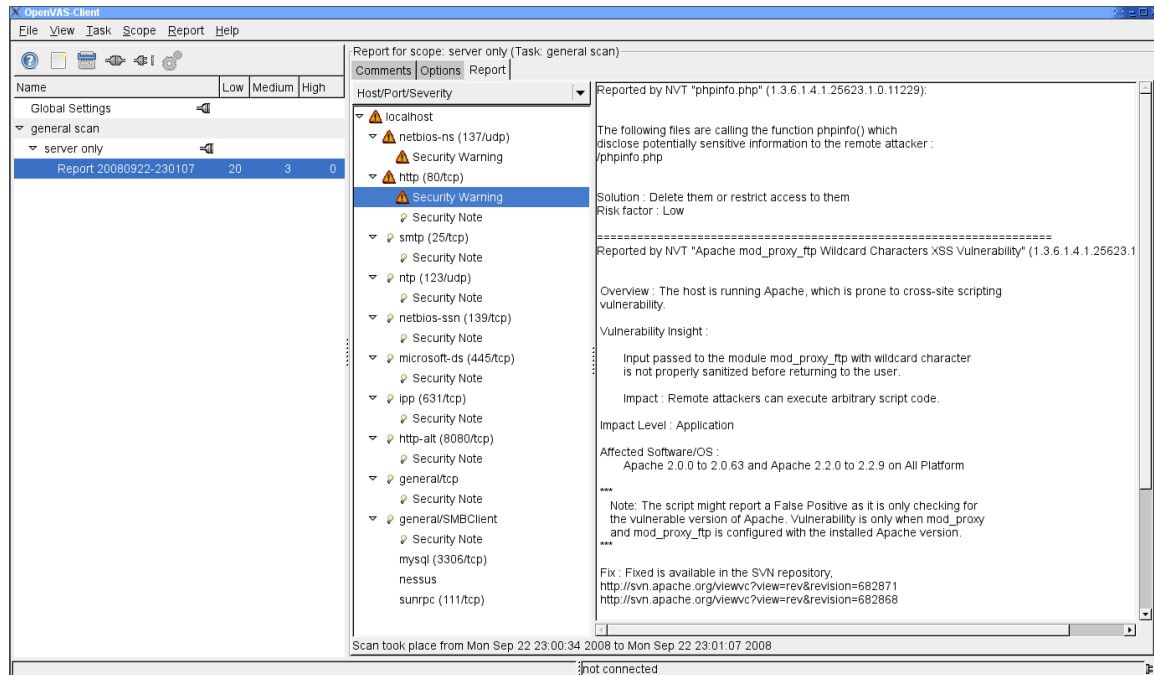
Starting nmap V. 2.54BETA22 ( www.insecure.org/nmap/ )
Interesting ports on (207.162.105.3):
(The 1540 ports scanned but not shown below are in state: filtered)
Port      State      Service
80/tcp    open      http
3128/tcp  open      squid-http

Nmap run completed -- 1 IP address (1 host up) scanned in 165 seconds
```

Une version graphique est disponible pour Linux et Windows.

Nessus/OpenVAS

Nessus/OpenVAS est un outil de détection des vulnérabilités qui effectue un balayage des ordinateurs du réseau à la recherche de logiciel boguer, de portes dérobées etc...



John the Ripper

John the Ripper est un programme qui décode les mots de passe. Pour un administrateur réseau, il est indispensable de s'assurer que les utilisateurs protègent leur compte usagé à l'aide d'un mot de passe qui sera difficile à décoder. Pour ce faire, un administrateur utilisera régulièrement un outil de décodage de mot de passe comme crack, L0phtCrack ou John the Ripper. Lorsque l'administrateur découvre un compte usagé mal protégé il doit le verrouiller avant qu'un pirate découvre cette porte d'accès. Ces comptes ne seront ré-activés qu'après changement de mot de passe sérieux. L'intérêt de John the Ripper c'est qu'il est efficace et peut décoder aussi des mots de passe Windows ou Linux.

```
[root@pc-00068 run]# ./unshadow /etc/passwd /etc/shadow > passwd.2
[root@pc-00068 run]#
[root@pc-00068 run]# ./john passwd.2
```

```
Loaded 2 passwords with 2 different salts (FreeBSD MD5 [32/32])
killer          (tito)
bonjour         (titi)
guesses: 2  time: 0:00:00:03 100% (2)  c/s: 951  trying: bonjour
```

Références

Donald L. Pipkin, « Sécurité des systèmes d'information », CampusPress, 2000.

Thomas W. Shinder, « Sécurité sous Windows 2000 Server », Eyrolles, 2002.

Stefen Norberg, « Securing Windows NT/2000 Servers for the Internet », O'Reilly, 2001.

Elizabeth Zwicky, Simon Cooper et Brent Chapman, « Building Internet Firewalls », deuxième édition, O'Reilly, 2000.

Eric Maiwald, « Sécurité des réseaux », Campus press, 2001.

Aron Hsiao, « Sécurité sous Linux », Campus press, 2001.